

A revoked agent key must fail on the next paid request. A new key must not pay until a human re-proves.

Rebind is that gate. The registry can mark a key revoked or rotated. The paygate re-reads that mark on every grant. World ID for Agents is how the new key earns the right to pay. It is not how a person logs into the app.

Rotation and “revoke” already fail in production systems. The session keeps working.

STOLEN SESSION, NOT A STOLEN KEY

RelayShield, on the 2026 Claude infostealer mail: rotating a key fixes nothing, because the attacker copied an authenticated session. Changing a password does nothing unless the platform kills existing sessions. Many do not.

blog.relayshield.net/this-is-not-llmjacking-and-rotating-your-key-will-not-fix-it

THE STANDARD ALREADY SAYS SO

OWASP ASVS 5.0 requirement 7.4.1: when termination is triggered, the app must disallow any further use of the session. Stateful sessions are invalidated on the backend. A token that lives until expiry is not terminated.

github.com/OWASP/ASVS/blob/v5.0.0/5.0/en/0x16-V7-Session-Management.md

BOTH CONTROLS, OR NEITHER

Obsidian Security: if you force a password reset, the attacker still holds the session token. If you only revoke sessions, stolen credentials log in again.

You need rotation and session kill together.

obsidiansecurity.com/blog/credential-theft-vs-token-theft

AN AGENT PLATFORM SHIPPED THE BUG

Flowise, a tool for building agent workflows, CVE-2025-71335, CVSS 8.6.

Before 3.0.10, changing the password left existing session tokens valid. CWE-613. The password change did not do the job users thought it did.

vuln.today/cve/CVE-2025-71335 · [GHSA-x7rp-qj2h-ghgw](https://github.com/advisories/GHSA-x7rp-qj2h-ghgw)

The actor is non-human, keeps calling APIs, and can be copied.

- NHIMG: an agent session must be checked on every request. Expiry alone does not close access. Rotation changes the secret, not the live artefact already issued. They point at OWASP's Non-Human Identity Top 10 and NIST's split between authenticators and sessions.
- Moltbook operators, in public posts, not in a vendor blog: one person registered 41 accounts and farmed karma; X verification is "tissue paper"; "the tools to verify one unique agent simply don't exist yet."
- World's own AgentKit essay is one more voice in that chorus. It is not the evidence. The same company's AgentBook issues #37 and #23 only show that this registry, specifically, still has no revoke and no unregister.

nhimg.org/articles/session-revocation-and-sign-out-everywhere-for-users-and-ai-agents · [moltbook.com posts ad58b8f, 61dec01c, 3e40acc4](https://moltbook.com/posts/ad58b8f,61dec01c,3e40acc4)

A paygate that treats revoke as a request-time decision, and rotate as a new human proof.

- Register key K for a human. A signed request for the paid resource is granted.
- Revoke K. Win mode returns 403 on the open session and on a fresh signature. The cookie from the first lookup is not authority.
- Rotate K to K2. K2 stays 403 until the server, not the client, records a validated rebind.
- That rebind is a World ID for Agents journey on sandbox.auth.world.org: request, human completes, server checks the ID token, then the grant.
- Foil mode is the before shot. It still grants after revoke, on purpose, so the demo can show the bug the standards describe.

Two commands. Opposite results. Same key.

NPM RUN FOIL-REVOKE · EXIT 0

Registry says K is revoked. The paid grant still returns 200, with the session and without it. Prints REVOKE_INEFFECTIVE. This is the Flowise-shaped hole, filmed on our paygate.

NPM RUN WIN-REVOKE · EXIT 0

After revoke, both requests are 403 revoked. K2 is 403 rebind required. A body that says validated does nothing. After the server mints and stores the subject, K2 gets 200. Prints REVOKE_ENFORCED and REBIND_GRANTED.

The win server is the default `npm run dev`. Foil mode is `FOIL_MODE=1`. Signatures in the film are a local sha256 stub, so the demo does not pretend to be a wallet.

Short answers.

Is this an on-chain AgentBook fix?

No. The registry is our policy list. We do not claim a mainnet opcode.

Is World ID the login?

No. The protected action is the paid grant after rotate. Denied, expired, or cancelled means K2 still cannot pay.

Is the win a free trial?

No. AgentKit's free-trial mode is a different product, and we are not building it.

Why would a judge believe the revoke?

Because the same signed request that succeeded before revoke fails after it, including the session that was already open. That is ASVS 7.4.1, applied to the agent key.

The film's rebind subject is minted by our server. A World App approval is the next wire.

- Discovery on `sandbox.auth.world.org` is real: device authorization, token endpoint, JWKS, pairwise subject.
- `POST /rebind/live/start` calls that device endpoint only when `WORLD_CLIENT_ID` and `WORLD_CLIENT_SECRET` exist. They do not, in this environment.
- The hackathon plugin can register that client. Its README refuses HTTP localhost callbacks, so the app needs one stable HTTPS URL first.
- A plain serverless function would forget the registry between revoke and the next grant. The prototype has to be one process, or a store both requests share.

Revoke that does not bind the next request is theater. Rebind is the request-time check, plus a fresh human proof before the new key pays.

Sources for the problem: RelayShield, Obsidian Security, OWASP ASVS 7.4.1, Flowise CVE-2025-71335, NHIMG on agent sessions, public Moltbook writeups. AgentKit #37 and #23 are the local shape of that same gap, not the reason the gap exists.